



Certification professionnelle

Titre professionnel: **Concepteur développeur d'applications**

RNCP: **37873**

Dossier Projet

Projet : M&C Billetterie

Rédacteur : Coulet Corentin

Date : 27/06/2025

1. Liste des compétences du référentiel couvertes par le projet

Le projet M&C Society permet de mobiliser l'ensemble des compétences attendues du titre professionnel "Concepteur Développeur d'Applications" (RNCP 37873).

Bloc 1 - Concevoir et développer des composants d'interface utilisateur en intégrant les recommandations de sécurité

Le développement du front-end en Next.js a permis de concevoir et d'implémenter une interface utilisateur claire, moderne et responsive. La charte graphique bleue, noir et blanche a été respectée afin d'assurer la cohérence visuelle du produit.

Des bonnes pratiques d'accessibilité ont été intégrées, notamment l'utilisation de contrastes adaptés, la navigation clavier et l'ajout de textes alternatifs sur les images.

La sécurisation des échanges a été prise en compte dès l'authentification, via la gestion des sessions utilisateurs et l'intégration de mécanismes de hachage (bcrypt) et de tokens (JWT).

Bloc 2 - Concevoir et développer la persistance des données en intégrant les recommandations de sécurité

La modélisation des données a été réalisée à l'aide de **PlantUML** pour définir un schéma Entité-Relation, avant d'être implémentée en **PostgreSQL** via l'ORM **Prisma**.

Le système gère la persistance des utilisateurs, des rôles, des événements, des billets et des commandes. Le projet intègre également les bonnes pratiques liées au RGPD : respect du droit à l'oubli, possibilité d'exporter ou de supprimer les données personnelles, ainsi que la sécurisation des accès aux données sensibles.

La sécurité des données est renforcée par l'utilisation de l'ORM, réduisant le risque d'injections SQL, et par la sanitisation des données utilisateurs.

Bloc 3 - Concevoir et développer une application multicouche répartie en intégrant les recommandations de sécurité

Le projet repose sur une architecture modulaire en couches hybride, adaptée à **Next.js 13+ App Router**, séparant clairement la logique métier (services spécialisés), l'accès aux données (repository via Prisma ORM) et les contrôleurs exposés via un adaptateur vers les API routes. Cette organisation assure une excellente **maintenabilité**, **testabilité** et **évolutivité**. L'intégration de Stripe pour les paiements et d'un système d'email transactionnel garantit une expérience utilisateur complète. Le système de rôles granulaire (USER/ORGANIZER/ADMIN) avec middleware **RBAC** assure une sécurité robuste et une gestion fine des accès.

2. Cahier des charges

2.1. Description de l'existant

La gestion d'événements implique souvent l'utilisation de plusieurs outils distincts pour les réservations, la billetterie, le suivi commercial et la relation client. Cette fragmentation peut nuire à la fluidité des opérations, ralentir la prise de décision et dégrader l'expérience des utilisateurs.

Le projet M&C Society répond à ce constat en proposant une solution centralisée et intuitive, pensée pour simplifier l'organisation d'événements tout en offrant aux utilisateurs finaux une expérience fluide et cohérente. L'objectif est de permettre aux organisateurs de gagner en autonomie, en efficacité et en visibilité sur leurs performances.

2.2. Reprise de l'existant

Il n'existe aucune version antérieure du projet. Il s'agit d'une création ex nihilo. Aucun nom de domaine ni hébergement n'est encore attribué.

Aucun patrimoine documentaire n'est à reprendre : ni ancien cahier des charges, ni spécification fonctionnelle.

2.3. Principes de référencement

Le projet vise un bon positionnement naturel dans les moteurs de recherche (SEO). L'objectif est de maximiser la visibilité des événements publics, tout en assurant un référencement clair des pages événementielles. Le recours aux balises structurées, à un plan de site dynamique, ainsi qu'à des URL claires et optimisées est prévu.

2.4. Exigences de performances et de volumétrie

La plateforme vise à accueillir jusqu'à 10 000 visiteurs uniques par mois en phase de lancement, avec une montée en charge progressive jusqu'à 50 000 utilisateurs mensuels. Le temps de réponse moyen attendu est inférieur à 300 millisecondes pour les actions courantes (navigation, consultation d'un événement). Une disponibilité de 99,5 % est exigée. Le catalogue pourra regrouper jusqu'à 1 000 événements actifs simultanément, avec des pics de consultation à prévoir lors des lancements ou campagnes de communication.

2.5. Multilinguisme & adaptations pour un public spécifique

Le site sera initialement disponible en français. Une ouverture à l'anglais est prévue dans une future phase. Le contenu sera géré de manière à faciliter les traductions ultérieures. L'accessibilité pour les publics en situation de handicap (notamment visuel) sera prise en compte à travers le respect des normes d'accessibilité (contrastes, navigation clavier, textes alternatifs).

2.6. Description graphique et ergonomique

2.6.1. Composants de la charte graphique

L'identité visuelle du site repose sur une charte moderne en rouge, noir et blanc.

Les éléments graphiques incluent :

- Un logo sobre et distinctif
- Une police lisible sans-serif, avec des tailles adaptées selon les supports
- Une palette principale : rouge vif, noir profond, blanc neutre
- Une cohérence graphique assurée sur toutes les pages

2.6.2. Design, Responsive design et autres exigences liées au design

Le site devra être **entièrement responsive** et offrir une **expérience utilisateur fluide** sur desktop, tablette et mobile. Le style visuel recherchée est un **design moderne**, légèrement minimaliste, avec des animations légères. La navigation sera claire, avec des appels à l'action visibles et une hiérarchie bien définie des contenus.

2.7. Besoins fonctionnels « métier »

2.7.1. Utilisateurs du projet

Les types d'utilisateurs concernés sont :

- Les visiteurs : navigation libre, inscription, achat de billets
- Les utilisateurs authentifiés : gestion de leur profil, historique d'achats
- Les organisateurs : création, édition et gestion d'événements
- Les administrateurs : modération, gestion des utilisateurs, statistiques

2.7.2. Informations relatives aux contenus

Les contenus disponibles incluent : fiches événements, visuels (affiches, photos), descriptions textuelles, vidéos intégrées, documents à télécharger (conditions générales, programmes). Le site respectera le RGPD : les données personnelles seront protégées, une politique de confidentialité sera affichée et le consentement explicite demandé pour la collecte de données.

2.7.3. Inventaire des besoins fonctionnels

Thème	Qui	Quoi	Pourquoi
Authentification	Utilisateur	Créer un compte	Participer à un événement
Authentification	Utilisateur	Se connecter / Se déconnecter	Gérer ses billets
Profil	Utilisateur	Modifier ses informations	Mettre à jour ses données
Gestion événements	Organisateur	Créer un événement	Le rendre visible au public
Billetterie	Visiteur	Acheter un billet	Participer à un événement
Administration	Admin	Modérer un événement	Maintenir la qualité du service
Statistiques	Admin	Consulter les indicateurs clés	Suivre les performances

Fonctionnalités supplémentaires envisagées :

- Espace client avec accès sécurisé
- Système de notification (email)
- Intégration d'un moteur de recherche interne
- Interface d'administration avec tableaux de bord
- Règles d'accès en fonction des rôles

2.8. Budget

Le budget total prévisionnel est estimé à **90 jours/homme** répartis comme suit :

Phase	Durée estimée
Analyse & Conception	15 j/h
Développement back-end	25 j/h
Développement front-end	20 j/h
Intégration & Tests	20 j/h
Documentation & Livraison	5 j/h
Réserves & imprévus	5 j/h

3. Présentation de l'entreprise et du service

Présentation de l'entreprise

M&C Billetterie est une jeune société française fondée en 2025, spécialisée dans les solutions de billetterie en ligne pour événements culturels, sportifs et professionnels de petite à moyenne envergure. Notre mission est de rendre la vente et le contrôle des billets simples, rapides et fiables pour les organisateurs comme pour le public. Basée en France et opérant en mode SaaS, M&C Billetterie s'adresse aux salles de spectacle, associations, festivals locaux, clubs sportifs, écoles et organisateurs d'événements B2B (salons, conférences). L'équipe, à taille humaine, réunit des profils techniques et opérationnels (produit, développement, support client, commercial) avec une culture de service et de transparence.

Présentation du service

La plateforme M&C Billetterie couvre l'ensemble du cycle de vie d'un événement: création (fiche événement, jauge, catégories de tarifs), mise en vente (page de vente responsive, paniers, codes promo), paiement sécurisé via un prestataire certifié, émission immédiate des billets (PDF/Wallet) et contrôle d'accès sur site (scan de QR codes via application mobile). Côté organisateur, un espace d'administration centralisé permet de suivre les ventes en temps réel, gérer les équipes (rôles simples), envoyer des confirmations et exporter les données essentielles (commandes, listes d'accès). Côté public, le parcours d'achat est pensé pour être clair et rapide: choix des billets, paiement, réception du billet et informations pratiques. La solution s'intègre avec les outils courants (emailing, paiement) et propose une API simple pour les besoins de base.

Positionnement et valeur apportée

M&C Billetterie mise sur la simplicité d'usage, la fiabilité opérationnelle les jours "chauds", et la proximité avec les organisateurs. Par rapport aux plateformes généralistes, notre proposition de valeur tient dans un outil léger, rapide à déployer, au coût maîtrisé et avec un accompagnement direct (support réactif, conseils de configuration). Pour les organisateurs, les bénéfices se mesurent en gain de temps, réduction des erreurs de contrôle à l'entrée et meilleure visibilité sur les ventes. Pour le public, l'expérience est fluide et sécurisée.

Engagements et conformité

Les données sont hébergées en Europe et traitées conformément au RGPD (finalités claires, minimisation, droits des personnes). Les paiements sont délégués à un prestataire certifié (les données de carte ne transitent pas par nos serveurs). Nous suivons des indicateurs simples et concrets: disponibilité de la plateforme, temps de réponse du tunnel d'achat, taux d'échec de paiement, et taux de satisfaction des organisateurs.

Modèle économique

Le modèle est volontairement transparent: une commission par billet émis et, selon les besoins, un petit abonnement mensuel pour activer des fonctionnalités additionnelles (contrôle d'accès avancé, exports étendus, intégration API). Aucun frais caché, et des tarifs adaptés au volume des événements.

4. Gestion de projet

Le projet a été mené de manière itérative en m'appuyant sur des outils de gestion modernes. L'objectif était de garder une vision claire de l'avancement, de suivre les priorités (MVP, documentation, tests etc), et d'assurer la traçabilité du code et des décisions techniques.

4.1 Méthodologie

Le projet a suivi une approche **itérative et incrémentale** : les fonctionnalités ont été développées par lots, testées, puis intégrées progressivement.

Cette méthode a permis d'ajuster certaines décisions en cours de route (organisation des DTOs, choix techniques, etc.).

4.2 Outils utilisés

- **Trello** : organisation des tâches en colonnes, permettant un suivi visuel et simple de l'avancement. (Backlog général, Sprint 1 Mise en place et fondations, Sprint 2 Création / Affichage d'évènements, Sprint 3 Achat et génération de billets, Sprint 4 Finalisation MVP et QA, En cours, Terminé, Bugs/QA à traiter, Priorités MVP V1)
- **GitHub** : gestion du code source, suivi des versions (Git), centralisation des commits et du travail effectué.
- **PlantUML (.puml)** : création des diagrammes (cas d'utilisation, activités, entités-relation, classes, architecture) afin d'assurer une modélisation claire et maintenable.

4.3 Suivi de l'avancement

- Les fonctionnalités majeures ont été planifiées selon les phases définies dans le cahier des charges (analyse, conception, développement, tests, livraison).
- Chaque tâche correspondait à une carte Trello, avec passage dans les colonnes au fur et à mesure.
- Les versions du code ont été balisées par des commits réguliers sur GitHub.

4.4 Gestion des risques et validations

- Une réserve de jours a été prévue pour gérer les imprévus (retards, corrections).
- Les diagrammes UML ont servi de référence pour valider les choix fonctionnels avant le codage.
- Les tests ont permis de confirmer la qualité des livrables avant la mise à disposition finale.

5. Spécifications fonctionnelles

L'application M&C Society repose sur une architecture en couches, avec une séparation claire entre les composants métier, la base de données, et les interfaces utilisateur. Les spécifications fonctionnelles suivantes ont été établies à partir du cahier des charges :

- Gestion des utilisateurs : inscription, connexion sécurisée, modification du profil.
- Gestion des rôles : visiteurs, organisateurs, administrateurs.
- Création, modification et suppression d'événements par les organisateurs.
- Achat de billets via une interface intuitive.
- Gestion d'un tableau de bord pour les administrateurs : statistiques, supervision des événements et utilisateurs.
- Interface responsive accessible depuis ordinateur, tablette et mobile.
- Respect des règles RGPD pour la gestion des données personnelles.

Diagrammes de cas d'utilisation :

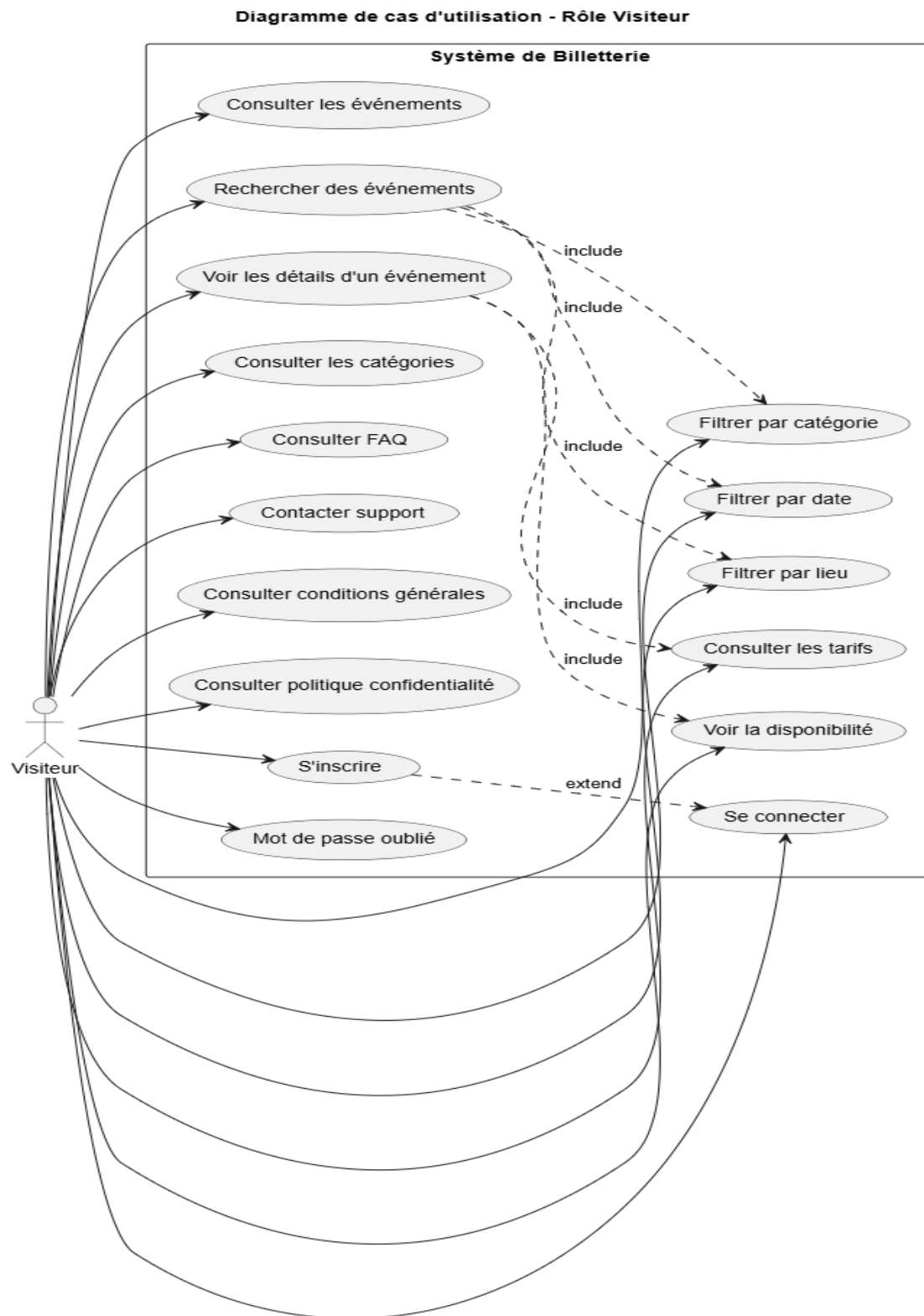


Diagramme de cas d'utilisation - Rôle Utilisateur

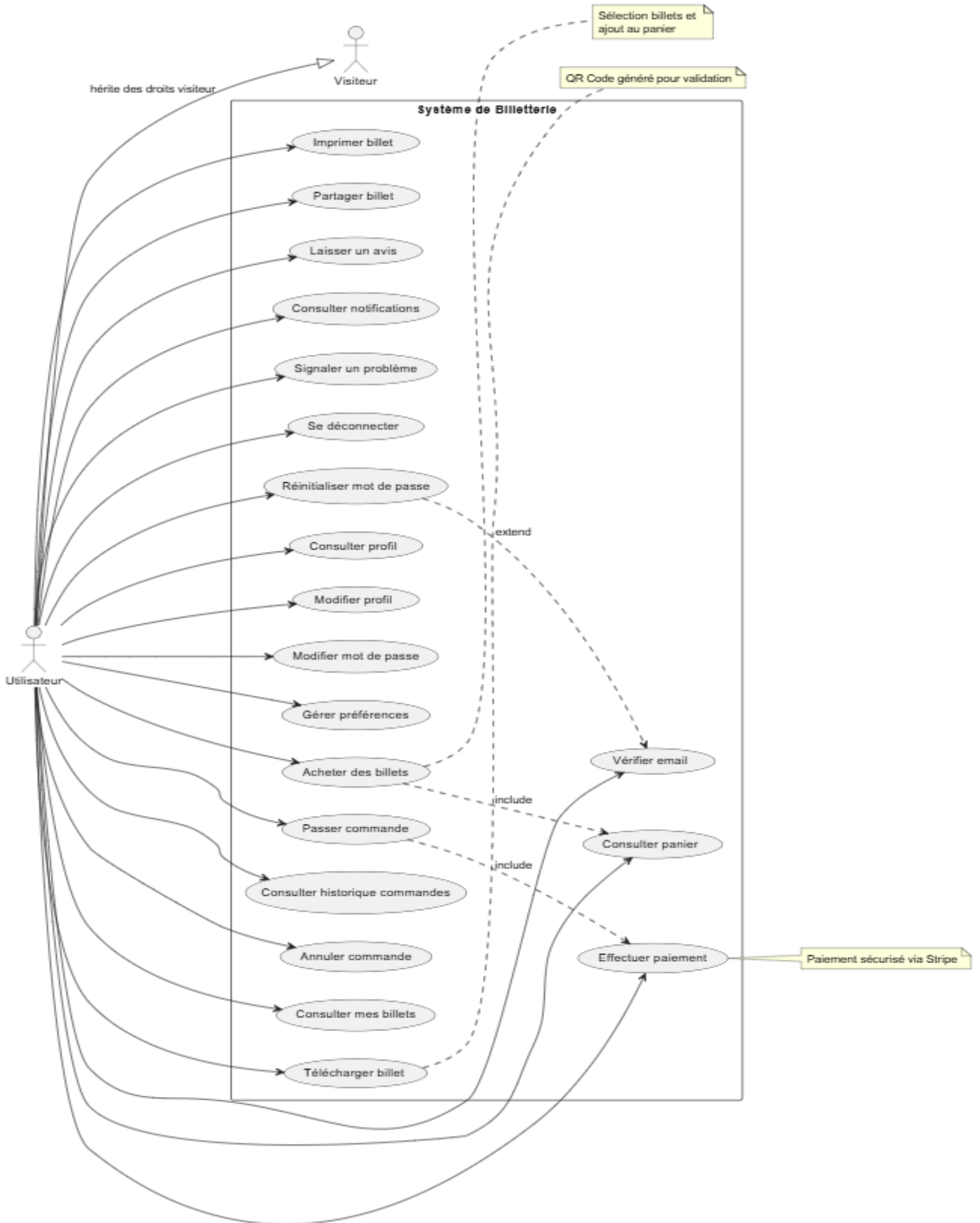


Diagramme de cas d'utilisation - Rôle Organisateur

hérite des droits utilisateur

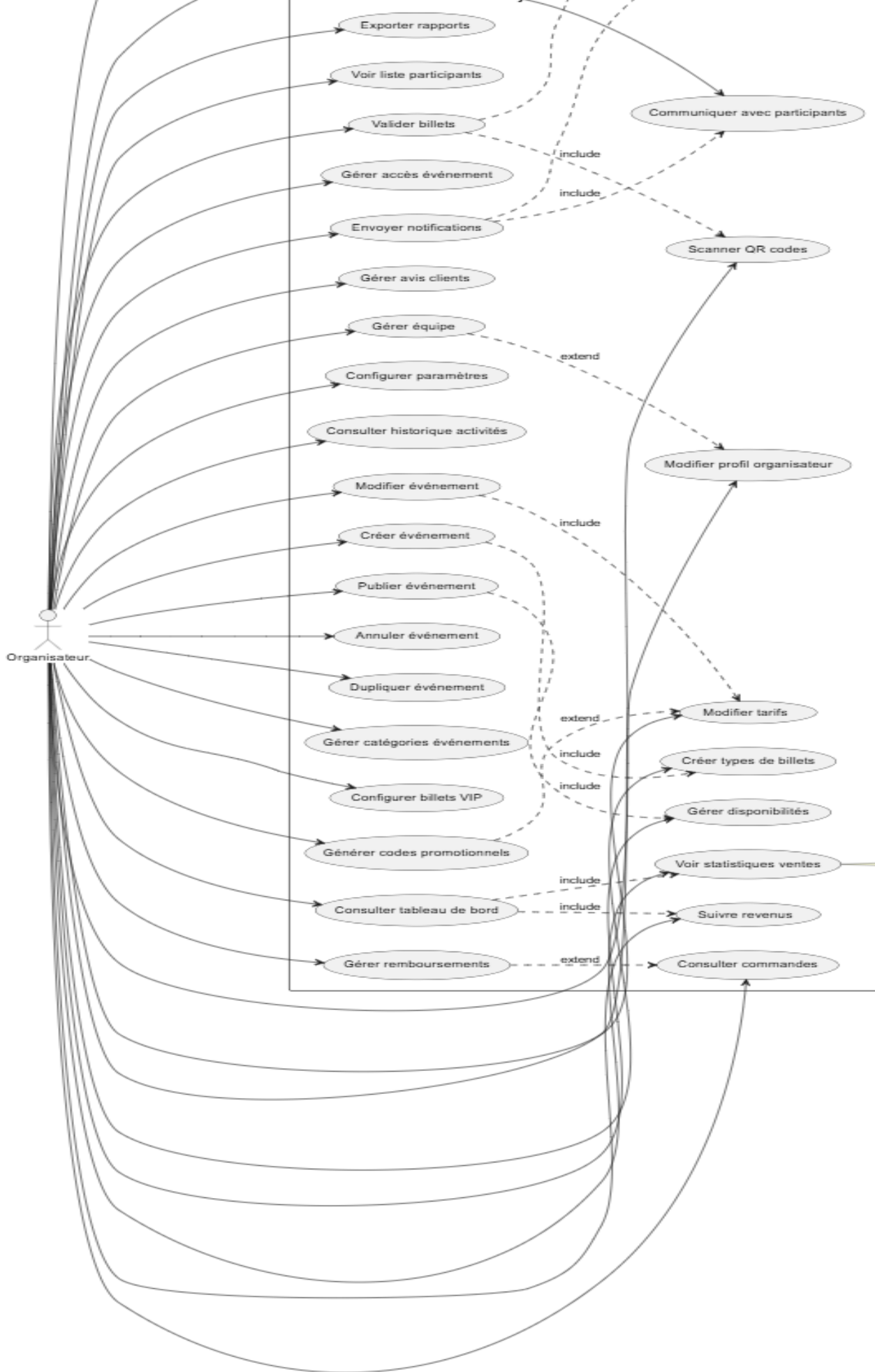


Utilisateur

Validation en temps réel
via QR code

Notifications :
- Email
- Push
- SMS

Système de Billetterie



6. Spécifications techniques

Environnement technique :

- **Backend** : Next.js avec Prisma ORM (PostgreSQL)
- **Frontend** : Next.js
- **Base de données** : PostgreSQL (hébergé localement ou en ligne)
- **Authentication** : par mot de passe avec hachage (bcrypt)
- **Outils** : Git, GitHub, Postman, Trello

Accessibilité :

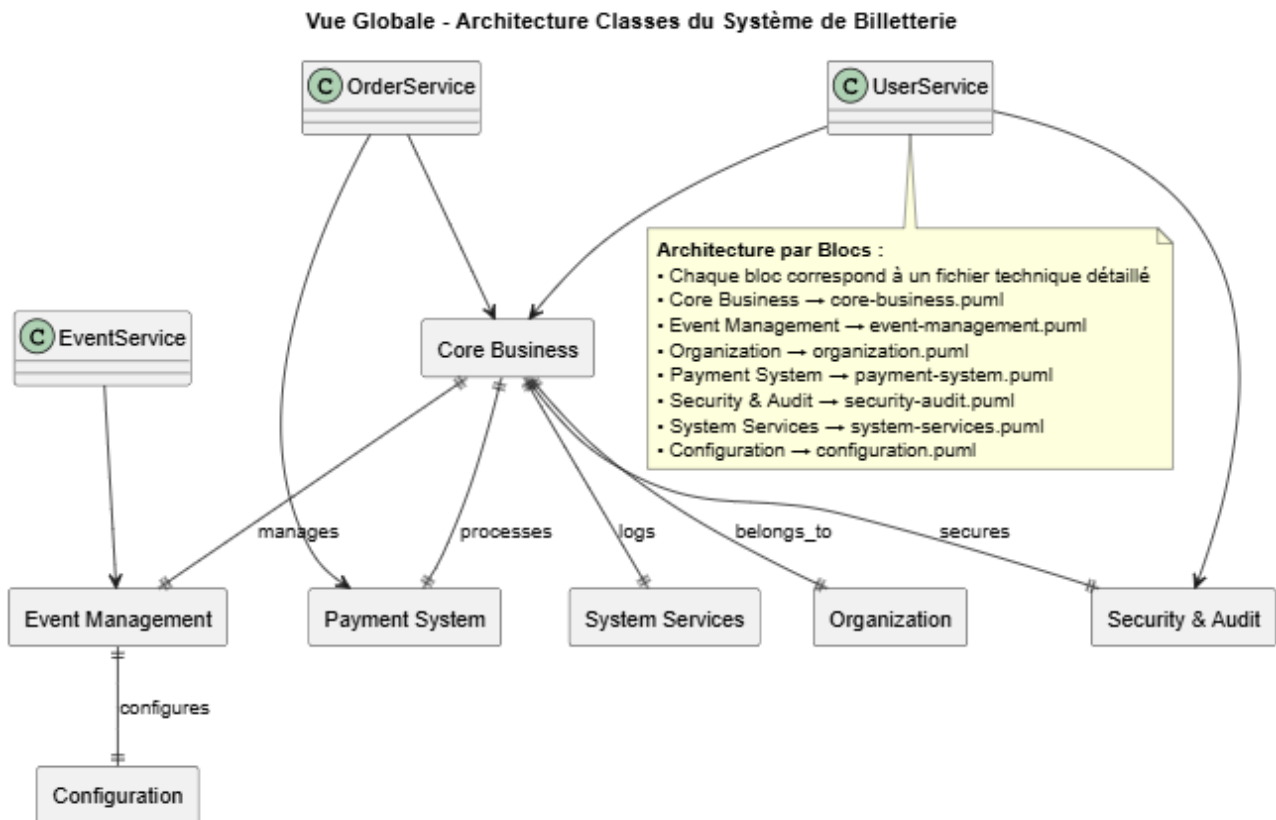
- Contrastes respectés pour les malvoyants.
- Navigation possible au clavier.
- Texte alternatif sur les images.

Référencement :

- URLs propres.
- Titres et métadonnées dynamiques.
- Sitemap automatisé (à prévoir dans une version postérieure).

Diagramme de classes :

Diagramme global avec tous les blocs :



Bloc Organisation :

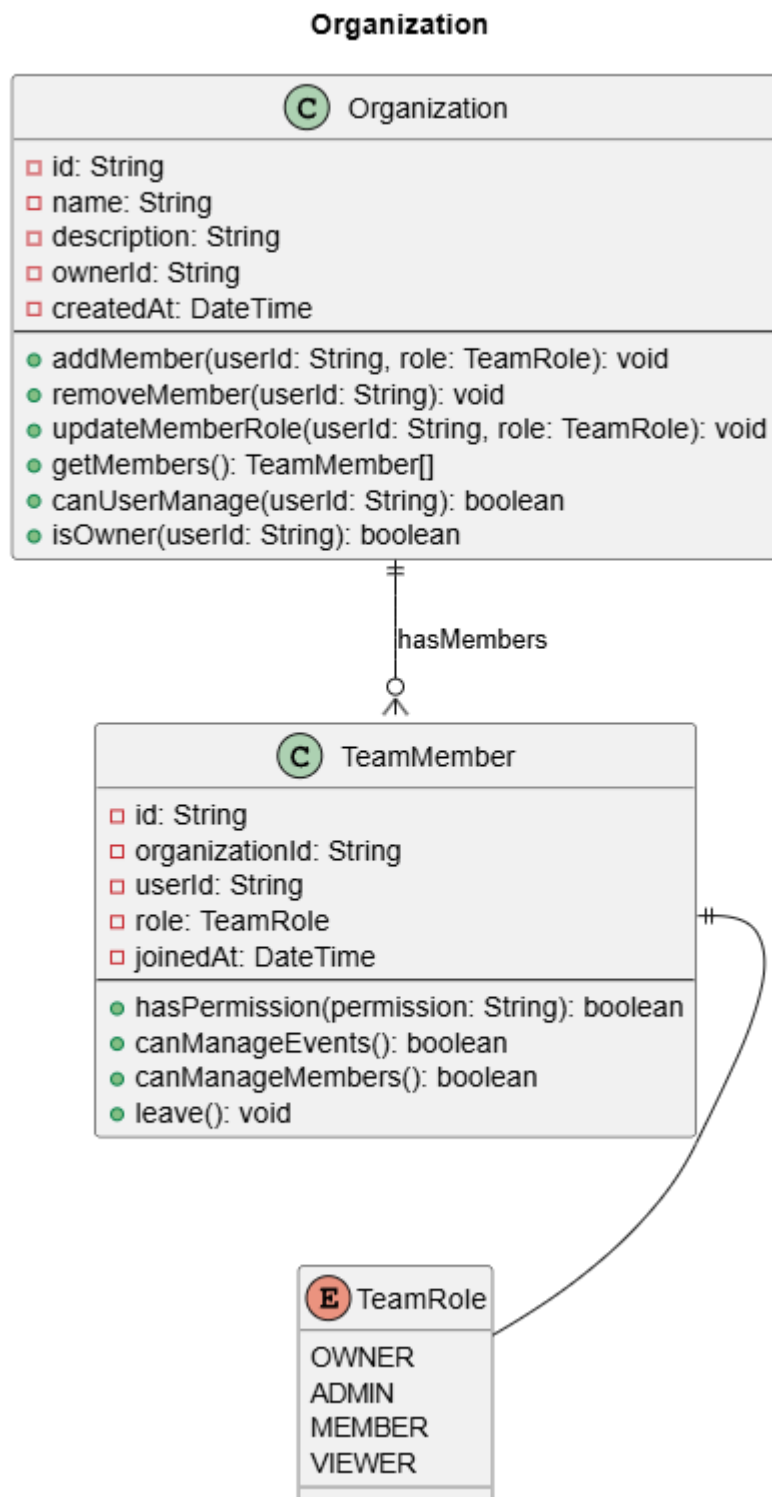
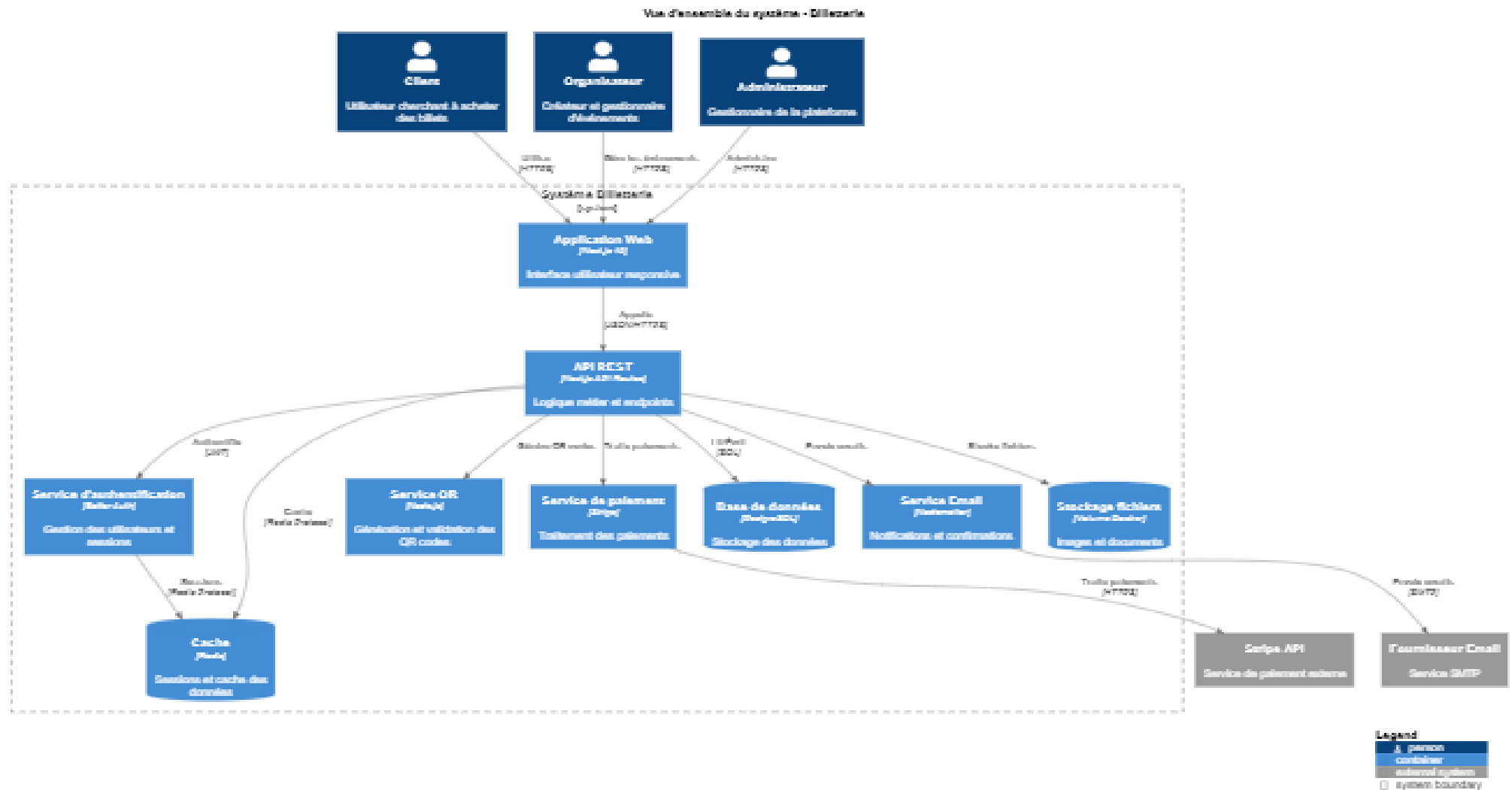
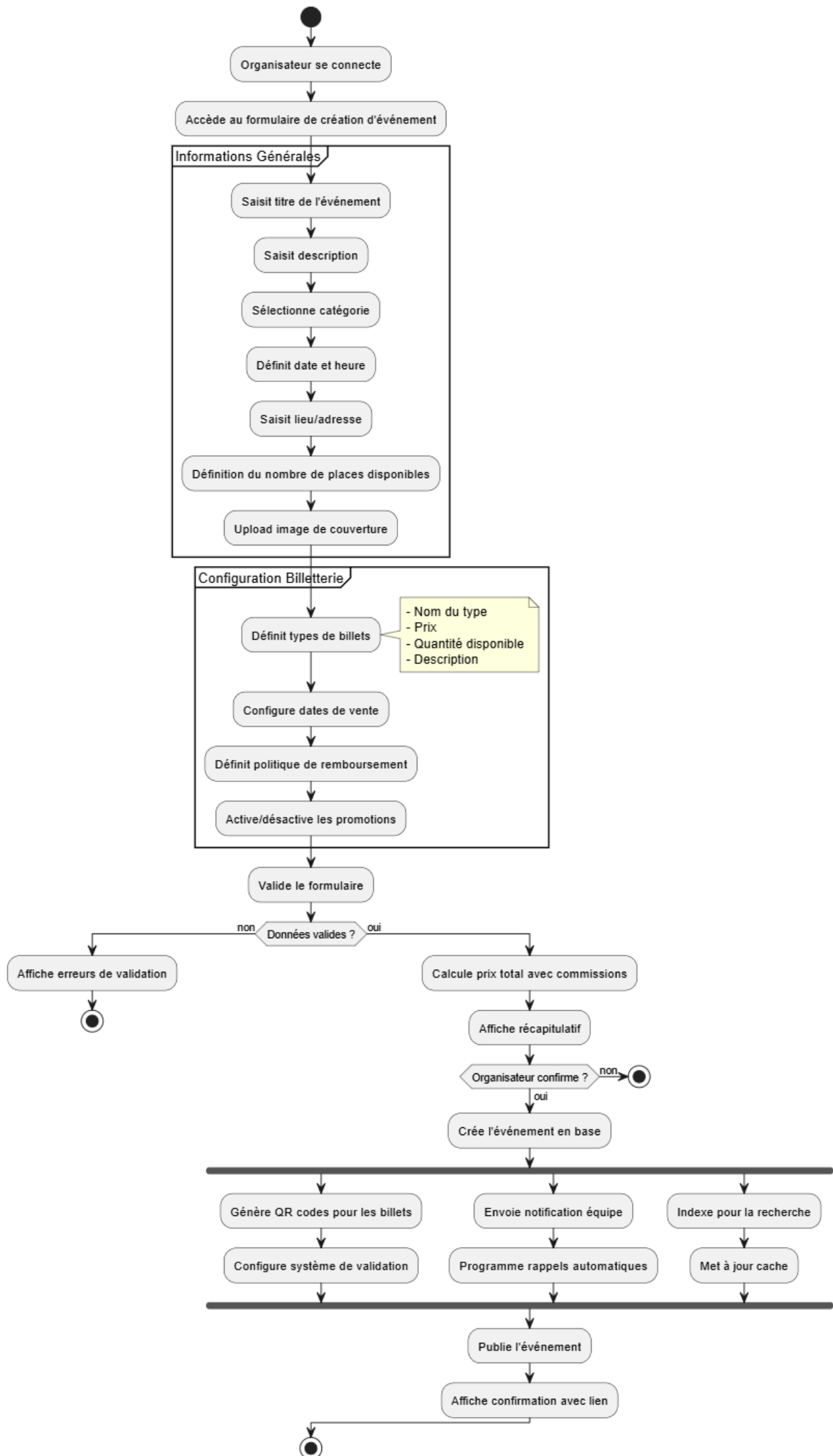


Diagramme d'architecture :

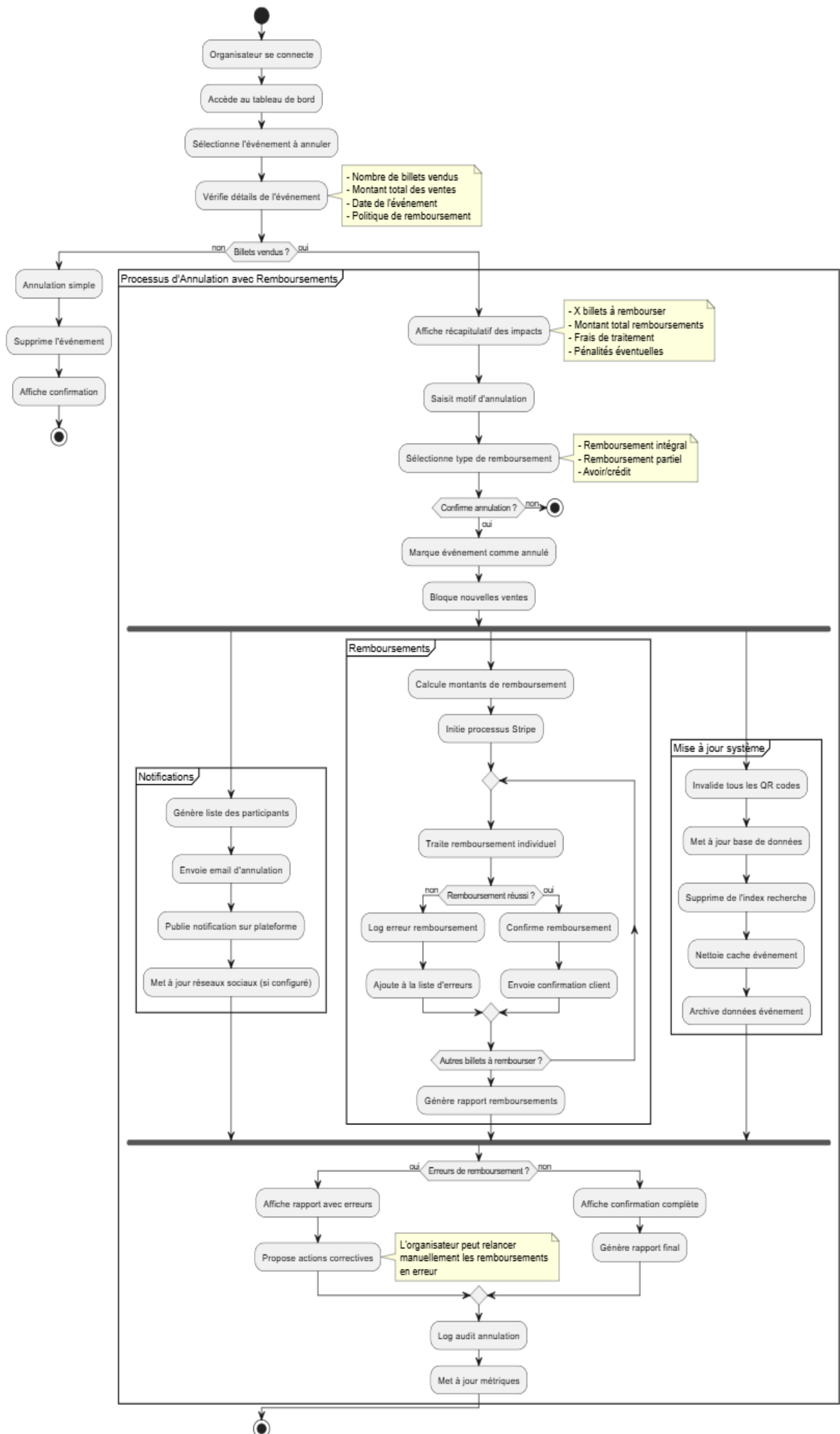


Diagrammes d'activités :

Création d'Événement



Annulation d'Événement par l'Organisateur



Annulation de Billet par l'Utilisateur

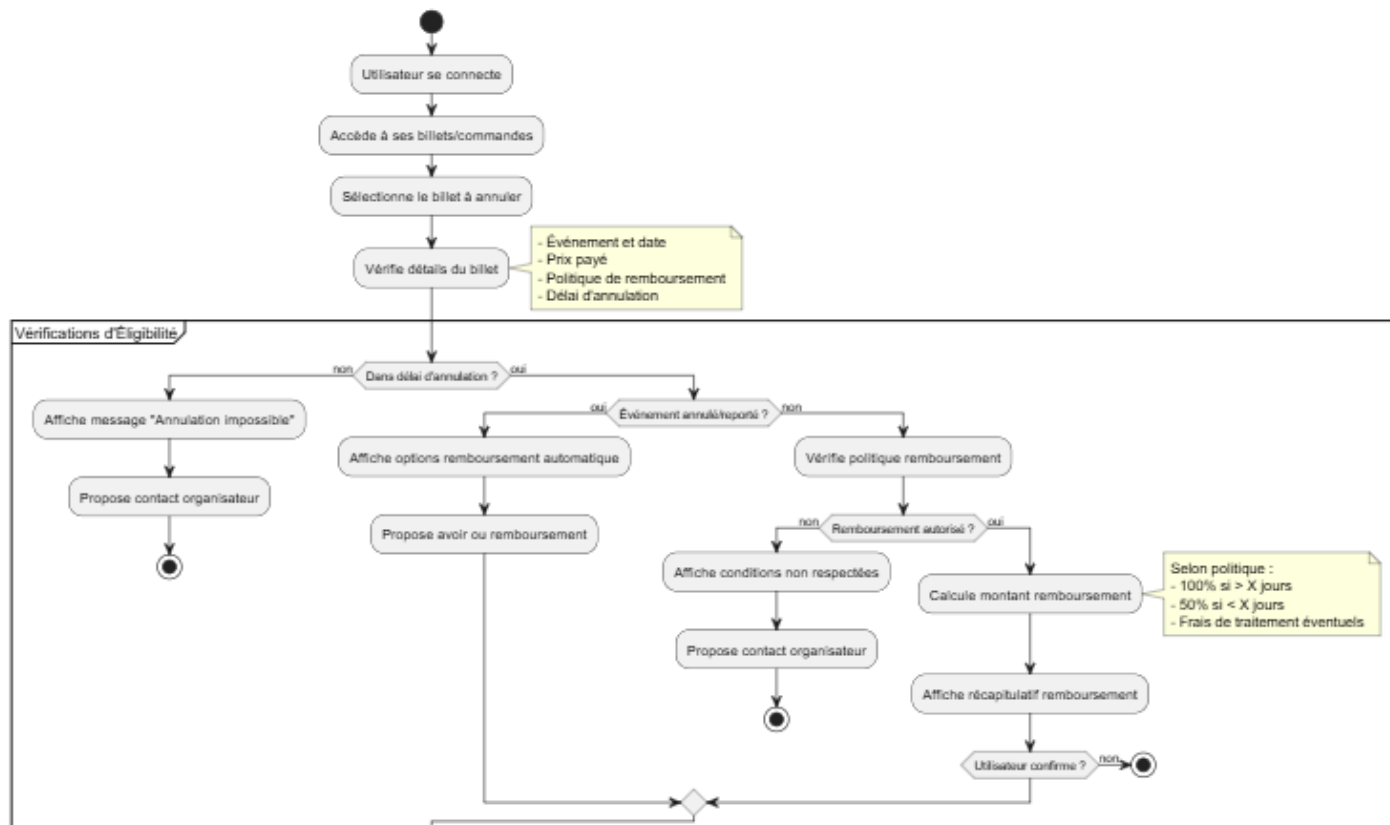
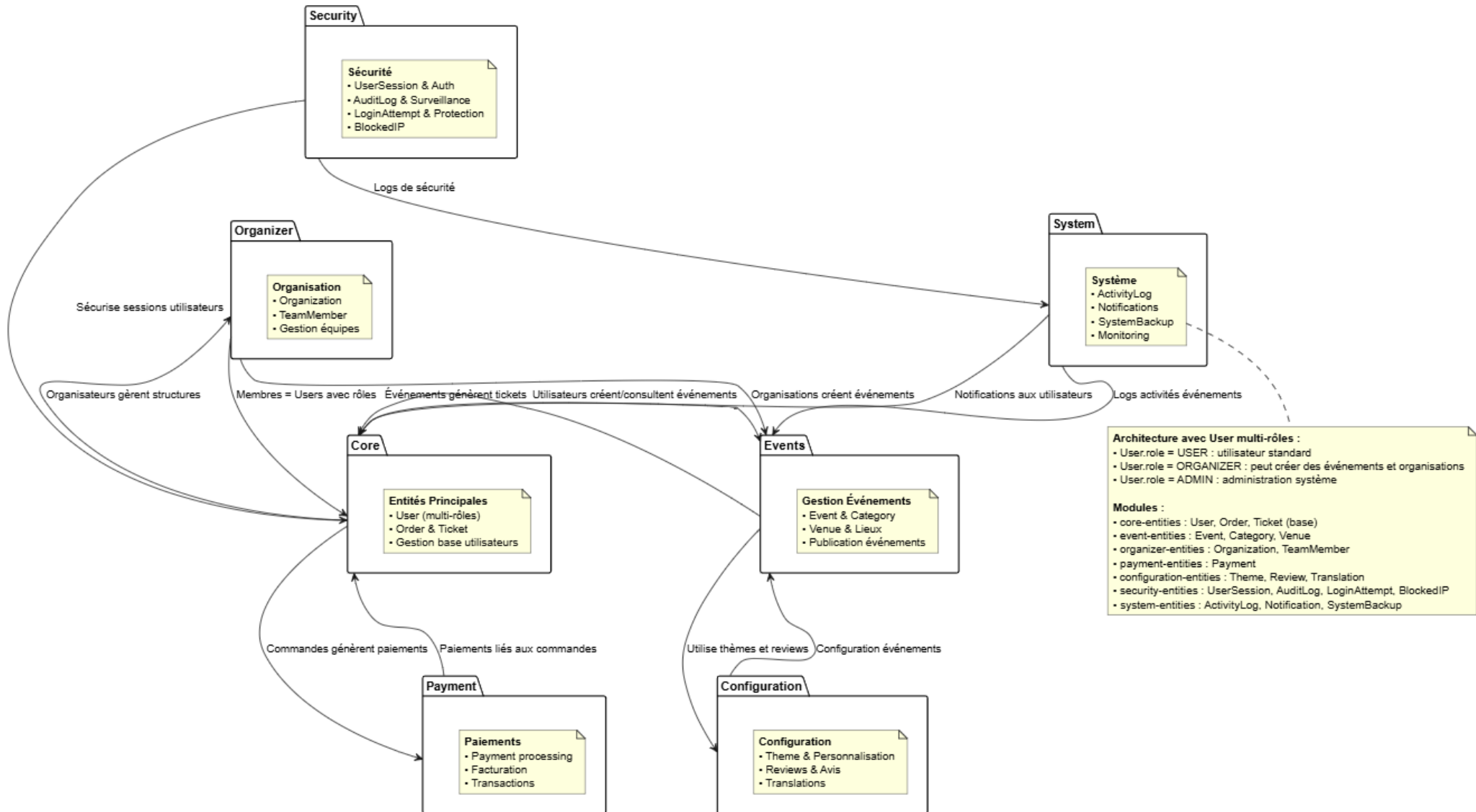


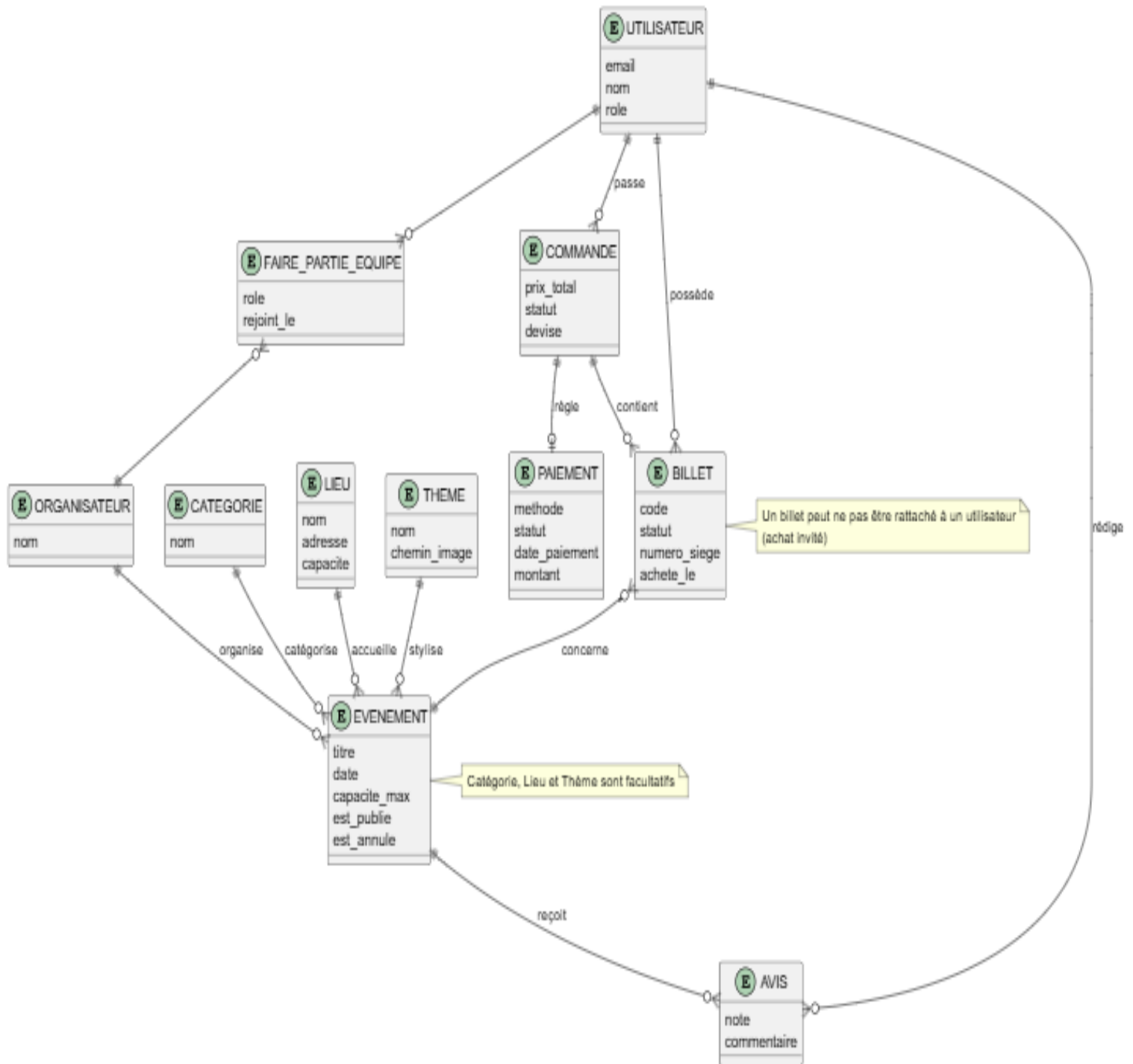
Diagramme d'entité-relation :

Vue Globale - Système de Billetterie

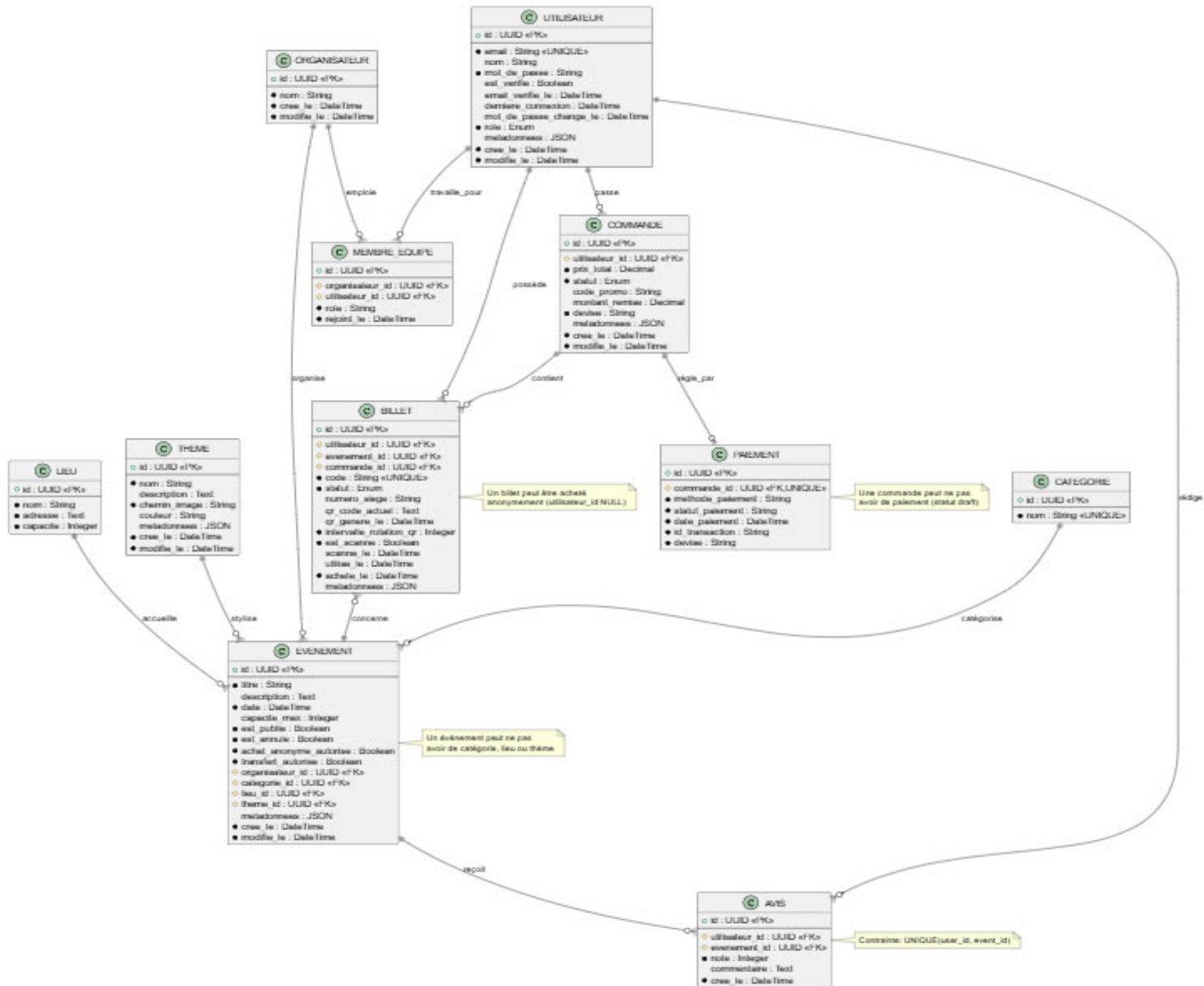


Merise :

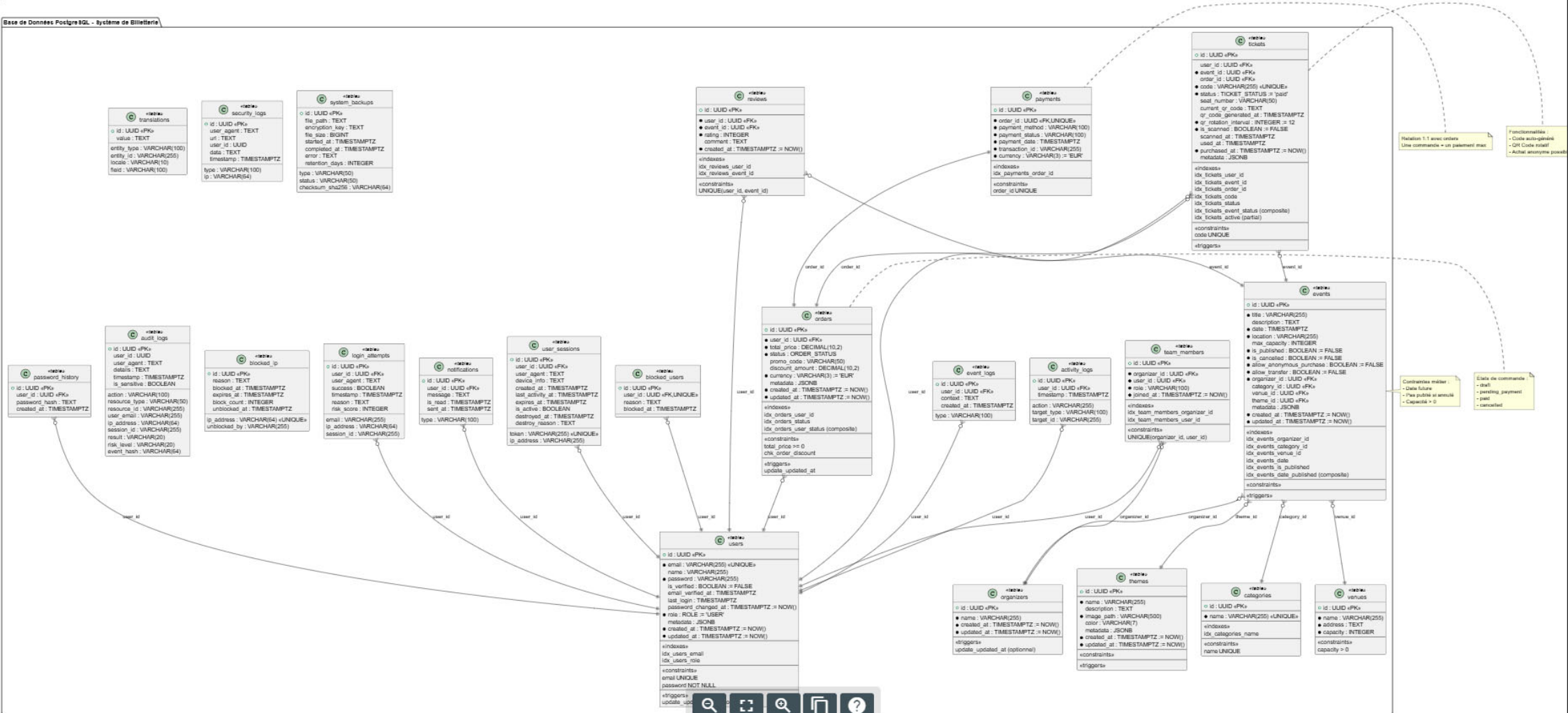
Modèle Conceptuel de Données (MCD) :



Modèle Logique de Données (MLD) :



Modèle Physique de Données (MPD) :



7. Réalisations

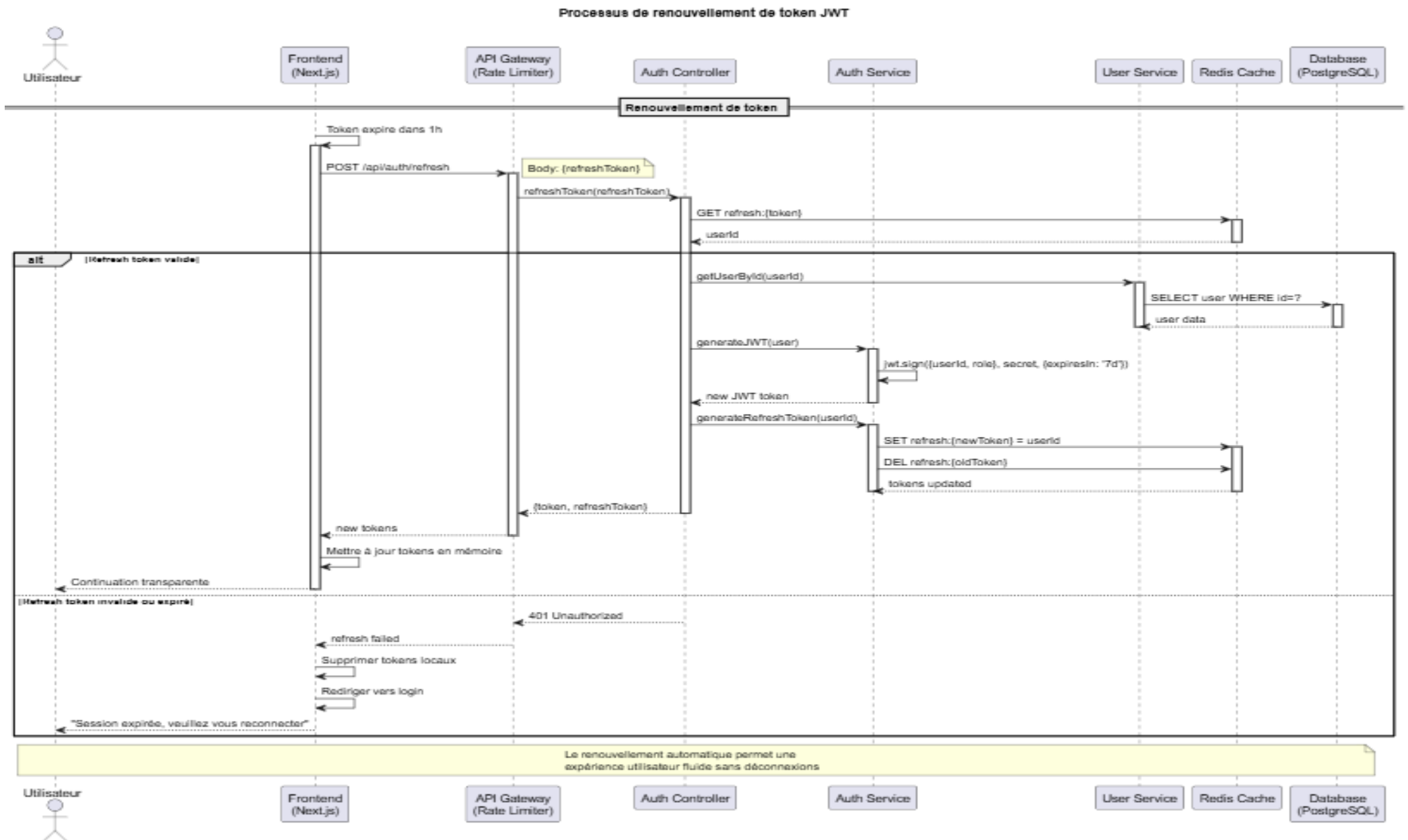
Fonctionnalités clés développées :

- **Inscription et connexion sécurisée**
- **Système de création et de gestion d'événements**
- **Achat de billets avec vérification des places disponibles**
- **Filtrage d'événements par catégorie, date ou lieu**
- **Tableau de bord administrateur avec statistiques clés**

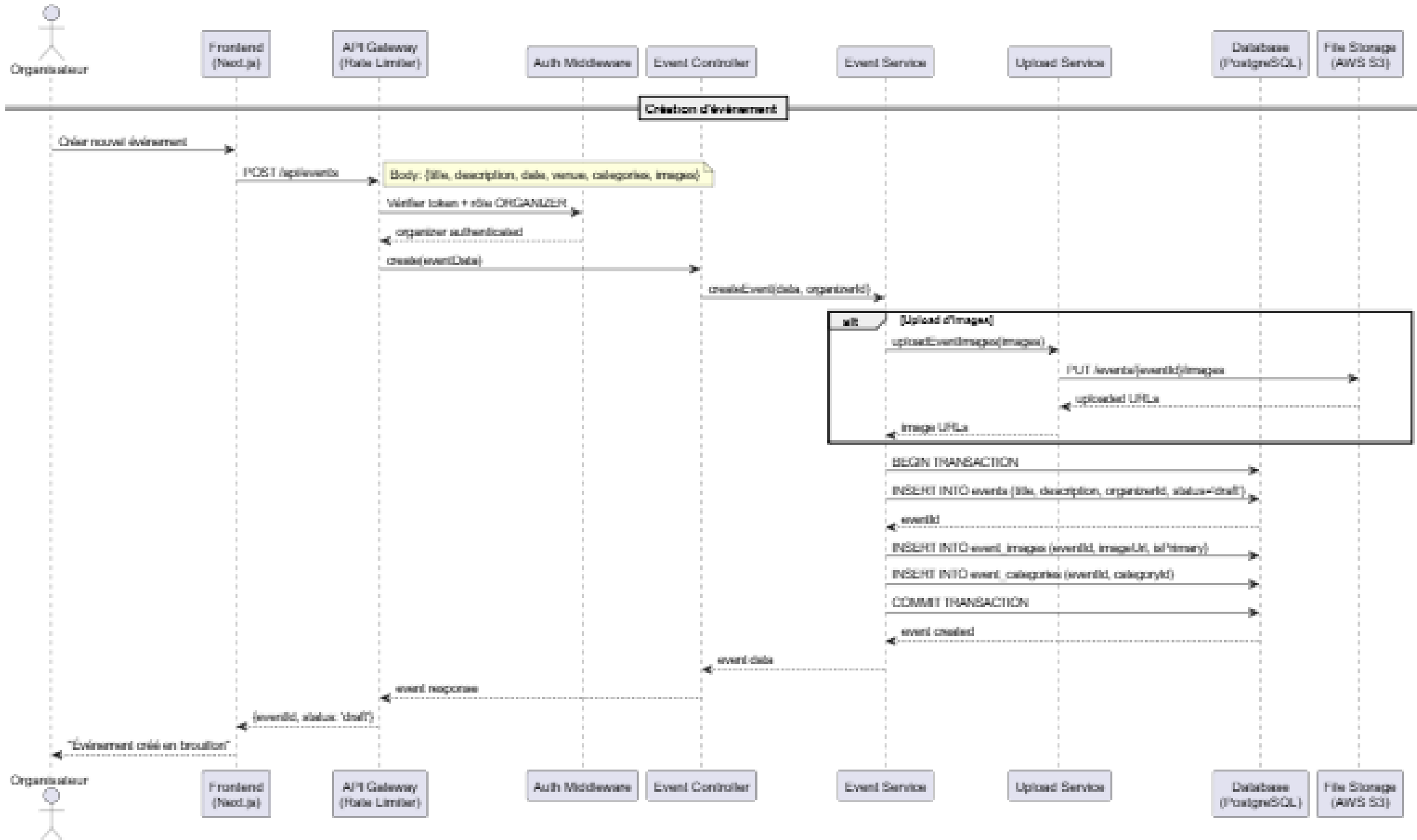
Exemple de code à intégrer :

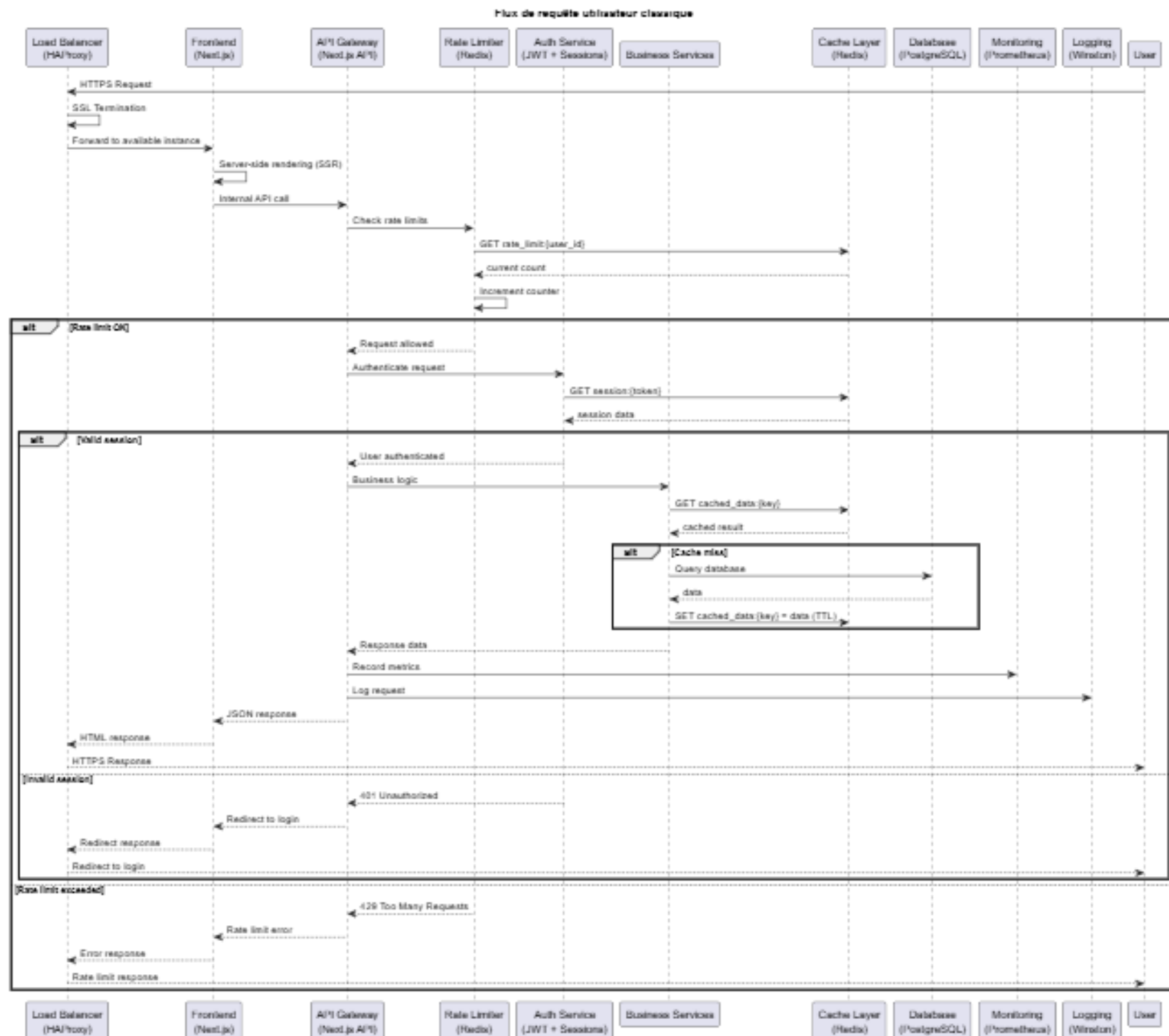
- DTO et validation lors de l'inscription.
- Middleware d'authentification.
- Requête Prisma pour créer un événement lié à un utilisateur.

Diagrammes de séquence :

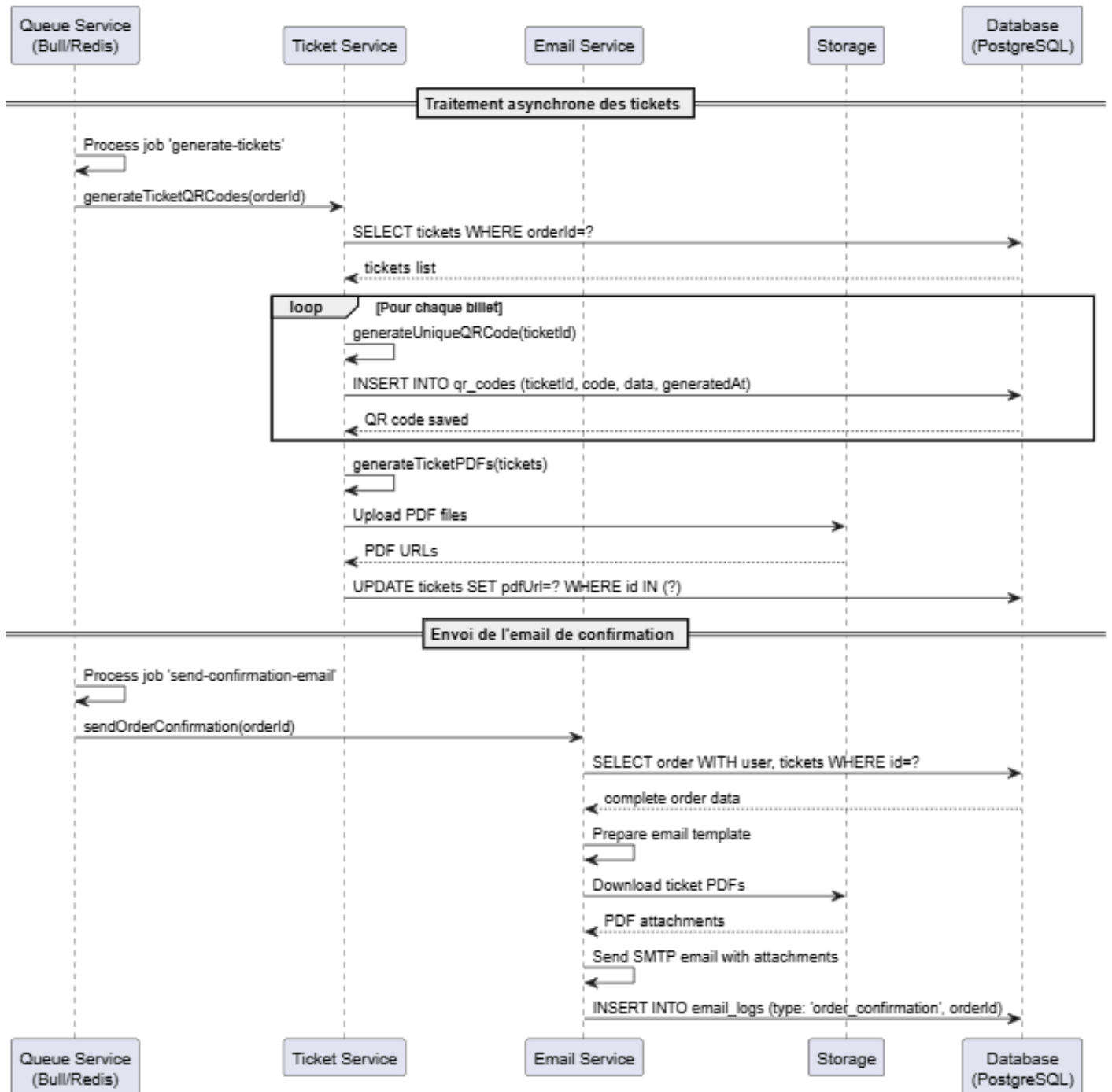


Création d'événement par l'organisateur





Génération des billets et envoi d'emails de confirmation



8. Éléments de sécurité de l'application

La sécurité de l'application M&C Society a été intégrée dès la phase de conception et repose sur une approche globale couvrant la protection des données, l'authentification, la prévention des attaques et le contrôle des accès. L'objectif est d'assurer la confidentialité, l'intégrité et la disponibilité des informations tout en respectant les normes et bonnes pratiques en matière de cybersécurité.

8.1 Protection des mots de passe

La protection des mots de passe constitue un élément fondamental de la sécurité de l'application :

- **Hachage robuste** : tous les mots de passe sont hachés avec l'algorithme bcrypt, configuré pour 10 à 12 rounds selon les besoins de performance et de sécurité.
- **Politique de mot de passe fort** : les mots de passe doivent comporter au minimum 8 caractères et inclure une majuscule, une minuscule, un chiffre et un caractère spécial, afin de limiter les risques de compromission par force brute ou dictionnaire.
- **Gestion de l'historique** : chaque modification de mot de passe est suivie via le champ `passwordChangedAt`, ce qui permet de détecter et de prévenir la réutilisation de mots de passe anciens ou compromis.
- **Aucune conservation en clair** : les mots de passe ne sont jamais stockés en clair dans la base de données, assurant une protection maximale en cas de fuite de données.
- **Suivi et audit** : toutes les opérations relatives aux mots de passe (création, modification, réinitialisation) sont enregistrées dans les journaux de sécurité, permettant une traçabilité complète.

8.2 Authentification sécurisée par JWT

L'authentification repose sur l'usage de **JSON Web Tokens (JWT)**, avec des mécanismes robustes pour la gestion des sessions et le contrôle d'accès :

- **Séparation des tokens** : l'application utilise des tokens d'accès de courte durée (15 minutes) et des tokens de rafraîchissement d'une durée plus longue (7 jours), afin de limiter l'exposition en cas de compromission.
- **Stockage sécurisé des sessions** : toutes les sessions utilisateur sont conservées dans la base PostgreSQL, permettant le suivi et la révocation centralisée en cas de besoin.
- **Invalidation automatique** : les sessions expirées sont supprimées automatiquement, et un administrateur peut révoquer manuellement toute session suspecte.
- **Contrôle d'accès basé sur les rôles (RBAC)** : l'application distingue différents niveaux d'accès (VISITOR < USER < ORGANIZER < ADMIN), garantissant que chaque utilisateur ne puisse exécuter que les actions autorisées selon son rôle.
- **Protection contre le détournement** : les tokens sont signés et vérifiés côté serveur, et les mécanismes de renouvellement sont sécurisés pour éviter l'usurpation d'identité.

8.3 Protection contre les injections et XSS

M&C Society met en œuvre des mécanismes stricts pour prévenir les attaques classiques telles que les injections SQL ou les scripts intersites (XSS) :

- **Validation stricte des entrées** : toutes les données fournies par les utilisateurs sont validées à l'aide de schémas robustes (via Zod), afin de garantir leur conformité et d'empêcher l'injection de code malveillant.
- **Utilisation de Prisma ORM** : le recours à un ORM typé et sécurisé permet de générer des requêtes préparées automatiquement, limitant fortement le risque d'injection SQL.
- **Filtrage des réponses** : les champs sensibles, tels que les mots de passe ou les informations financières, sont systématiquement exclus des réponses aux clients.
- **Headers de sécurité et CSP** : l'application applique une Content Security Policy (CSP) stricte et des headers HTTP de sécurité (X-Content-Type-Options, X-Frame-Options, Referrer-Policy) pour limiter le chargement de ressources non autorisées et réduire le risque d'attaques XSS.
- **Protection CSRF** : des jetons synchronisés sont utilisés pour protéger les formulaires critiques contre les attaques de falsification de requêtes intersites.

8.4 Gestion des accès CORS

La configuration Cross-Origin Resource Sharing (CORS) est optimisée pour limiter les échanges aux domaines autorisés :

- **Domaines autorisés** : seuls les domaines explicitement configurés peuvent accéder à l'API, réduisant le risque de requêtes non autorisées depuis des sites tiers.
- **Configuration par environnement** : les règles CORS sont adaptées selon l'environnement (développement, test, production) pour garantir flexibilité et sécurité.
- **Restriction des méthodes et headers** : les méthodes HTTP autorisées et les headers exposés sont strictement limités aux besoins fonctionnels, réduisant la surface d'attaque et les possibilités d'exploitation abusive.

8.5 Conformité RGPD

- L'application **M&C Society** respecte le Règlement Général sur la Protection des Données (RGPD) et met en œuvre les principes de transparence, de minimisation et de sécurité des données. Les mesures suivantes sont intégrées au projet :
- **Droit d'accès** : chaque utilisateur peut consulter l'ensemble de ses données personnelles à partir de son espace sécurisé.
- **Droit de portabilité** : un export complet et structuré de ses données est disponible au format **JSON** ou **CSV**.
- **Droit d'effacement (droit à l'oubli)** : l'utilisateur peut demander la suppression de ses données. La suppression est réalisée de manière sécurisée, avec prise en compte des contraintes légales (ex. conservation des données comptables pendant 10 ans).
- **Droit de rectification et d'opposition** : une API et une interface utilisateur permettent la modification de ses données, ainsi que la gestion des préférences (notifications, communication marketing).
- **Traçabilité et journalisation** : toutes les actions liées aux données personnelles (consultation, modification, suppression, export) sont consignées dans un **journal d'audit** horodaté.
- **Durée de conservation des données** :
 - Comptes utilisateurs : conservés tant que l'utilisateur dispose d'un compte actif. En cas de suppression ou d'inactivité prolongée (3 ans), les données sont anonymisées ou effacées sous 30 jours.
 - Commandes, billets et factures : conservés **10 ans** conformément aux obligations légales et fiscales.

- Données bancaires : aucune donnée sensible n'est stockée. Les paiements sont intégralement gérés par le prestataire Stripe. Seuls les identifiants de transaction nécessaires sont conservés pendant 10 ans.
- Logs techniques et de sécurité : conservés **1 an maximum** pour assurer la traçabilité et la détection des anomalies.
- Données marketing et prospection (newsletter, préférences, historique de navigation) : conservées **3 ans après le dernier contact** ou la dernière activité de l'utilisateur.
- **Suppression et anonymisation** : à l'issue des délais de conservation, les données sont supprimées de manière sécurisée ou anonymisées afin de ne conserver que des informations statistiques.

8.6 Mesures complémentaires

- En complément des mécanismes de protection intégrés (authentification, RGPD, sécurisation des accès), l'application **M&C Society** met en œuvre plusieurs mesures supplémentaires afin de renforcer la sécurité globale :
- **Rate limiting** : un système de limitation des requêtes est en place afin de prévenir les attaques par force brute et les abus (par exemple sur les formulaires de connexion ou de paiement). Ce mécanisme bloque ou ralentit automatiquement les requêtes excessives provenant d'une même source.
- **Monitoring et journalisation de sécurité** : les événements critiques (connexions suspectes, tentatives d'intrusion, échecs répétés d'authentification) sont enregistrés dans un **journal de sécurité**. Des alertes automatiques sont générées en cas de comportement anormal afin de permettre une réaction rapide des administrateurs.

- **Cookies sécurisés** : les cookies de session et d'authentification sont configurés avec les attributs **HTTPOnly** (inaccessibles depuis JavaScript), **Secure** (transmis uniquement via HTTPS) et **SameSite** (limitation du partage inter-domaines) afin de réduire les risques de vol ou de détournement de session.
- **Headers de sécurité** : l'application applique des en-têtes de sécurité conformes aux bonnes pratiques :
 - **HSTS (HTTP Strict Transport Security)** : impose l'utilisation du protocole HTTPS pour toutes les communications.
 - **CSP (Content Security Policy)** : limite le chargement des scripts, styles et ressources aux seules sources autorisées, afin de réduire les risques d'attaques XSS.
 - **Protections CSRF** : mises en place pour éviter la falsification de requêtes intersites (ex. utilisation de jetons synchronisés).
 - **Autres en-têtes complémentaires** : configuration des politiques X-Frame-Options, X-Content-Type-Options et Referrer-Policy pour limiter les risques d'injection et de fuite d'informations.

Ces mesures, combinées aux protections natives de la plateforme, contribuent à assurer un haut niveau de sécurité pour les utilisateurs et les organisateurs d'événements.

9. Plan de tests

La qualité et la fiabilité de l'application M&C Society ont été assurées par la mise en place d'une stratégie complète couvrant l'ensemble du cycle de vie du développement.

9.1 Stratégie de tests

L'approche adoptée repose sur une pyramide de tests :

- **Tests unitaires (≈70 %)** : validation de la logique métier isolée (services, contrôleurs, utilitaires).
- **Tests d'intégration (≈20 %)** : validation des interactions entre les composants (base de données, services externes comme Stripe et SMTP).
- **Tests end-to-end (≈10 %)** : validation des parcours utilisateurs complets (visiteur, organisateur, administrateur).

9.2 Organisation et outillage

- **Framework de tests** : Jest avec support TypeScript (`ts-jest`).
- **Mocking** : Prisma (base de données), Stripe (paiements), Email (notifications), fichiers statiques.
- **Validation des entrées** : via schémas Zod.
- **Couverture** : rapports générés (Istanbul/LCOV) avec un objectif minimal de **80 % global**, et **95 % sur les modules critiques** (paiements, sécurité).
- **CI/CD** : exécution automatisée des tests avec reporting (console, JSON, HTML).

9.3 Types de tests effectués

- **Unitaires :**

- AuthService (hachage, validation des mots de passe, JWT).
- TicketService (génération, validation des billets).
- PaymentService (paiement et remboursement via Stripe).
- EventService (gestion des événements et réservations).

- **Intégration :**

- Base de données PostgreSQL via Prisma (CRUD, migrations, transactions).
- Services externes : Stripe (paiements en mode test), SMTP (envoi d'e-mails), Redis (cache).
- Workflows complets : processus de réservation, création d'événement, administration.

- **API :**

- Routes publiques (consultation événements, inscription, connexion).
- Routes protégées (achat de billets, gestion de profil).
- Routes administrateur (gestion utilisateurs, modération événements, configuration système).

- **End-to-End (E2E) :**

- **Visiteur** : recherche et achat de billets.
- **Organisateur** : création et gestion d'événements, suivi des ventes.

- **Administrateur** : modération, gestion des utilisateurs et statistiques.
- **Sécurité et conformité** :
 - Tests anti-injections SQL et XSS.
 - Vérification des mécanismes CSRF et authentification JWT.
 - Validation RGPD (export/suppression des données).
 - Conformité PCI DSS pour les flux de paiement.
 - Tests d'accessibilité (A11Y).

9.4 Maintenance et évolutions

- Les tests sont organisés de façon modulaire et maintenus en parallèle du code.
- Des **scripts automatisés** facilitent l'exécution en local, en CI/CD et le seed de données de test.
- Les tests sont révisés régulièrement pour supprimer les doublons, renforcer la couverture et documenter les nouvelles fonctionnalités.
- Les métriques de performance et de sécurité sont surveillées (temps d'exécution < 30s pour la suite complète, monitoring mémoire).

10. Jeu d'essai de la fonctionnalité la plus représentative

Fonctionnalité testée : Achat de billets multi-événements avec sécurité avancée, gestion de stock, paiement sécurisé, génération de billets et notifications automatiques.

Objectif : Valider le parcours complet de l'utilisateur, de l'authentification à la validation des billets, tout en garantissant la sécurité, la fiabilité et la traçabilité.

Scénario de test :

1. **Authentification sécurisée :** connexion avec JWT, suivi des tentatives (LoginAttempt), détection d'IP suspecte, rate limiting.
2. **Sélection multi-billets :** choix de 2 billets VIP et 1 billet Standard pour deux événements distincts, avec vérification en temps réel de la disponibilité.
3. **Création de commande :** orchestration via OrchestrationService, validation des stocks et génération sécurisée du PaymentIntent Stripe.
4. **Paiement sécurisé :** validation 3D Secure, traitement des webhooks Stripe avec signature cryptographique et transactions atomiques.
5. **Génération des billets :** création de QR codes uniques avec rotation programmée, chiffrement AES-256.
6. **Notifications automatiques :** envoi d'emails de confirmation et de billets, notification in-app.

7. **Sécurité et tests avancés** : prévention de la réutilisation de QR codes, validation de checksum et gestion des billets expirés.
8. **Validation à l'entrée** : scan QR code via API, vérification multicouche (format, signature, expiration, double usage), mise à jour du statut isScanned.
9. **Audit et surveillance** : enregistrement dans AuditLog, mise à jour des sessions, suivi des métriques en temps réel.

Résultats attendus :

- Commande status: 'paid', totalPrice: 95,50€
- Paiement confirmé (paymentStatus: 'COMPLETED')
- 3 billets avec QR codes uniques et rotation programmée
- 2 emails envoyés et notification in-app
- Traçabilité complète et audit conforme GDPR
- Stock et transactions sécurisés, processus atomique

Conclusion : Ce scénario illustre le fonctionnement global du système et permet de vérifier l'ensemble des fonctionnalités critiques de manière sécurisée et automatisée.

11. Veille sur les vulnérabilités de sécurité

Une veille régulière a été effectuée autour de ces sujets :

- Bonnes pratiques d'**authentification** en Next.js
- Failles fréquentes (XSS, CSRF, injections SQL)
- Pratiques RGPD : données personnelles, droit à l'oubli
- Utilisation des alertes GitHub sur les dépendances
- Mise à jour des packages critiques (ex. Prisma, JWT)

Sources utilisées : owasp.org, blog.risingstack.com, GitHub Security Advisories, X (twitter), Instagram, LinkedIn.